

MD PnP - PATCH

Medical Device Failure Modes and Remediation Workflows

Version: 01 (Date: May 11, 2025)

1. Purpose

This document provides way to organize discussions around how hospitals identify, triage, and manage medical-device failures, vulnerabilities, downtime, and remediation decisions. *Current practice varies across hospitals, departments, and device categories.* Rather than following one common or well-established method, these decisions may be handled through a combination of local clinical engineering practices, IT/security processes, vendor guidance, downtime procedures, cross-team coordination, and clinical and regulatory considerations. A key challenge is that the required activities are not always integrated into a single process for assessing how a device-level vulnerability or technical failure affects clinical workflow, operational continuity, remediation timing, and return-to-service requirements. For example, a cybersecurity finding may identify a vulnerable device, but the operational decision may still depend on where the device is used, what clinical function it supports, whether a backup exists, what downstream systems depend on it, and whether remediation should be delayed to avoid interrupting patient care. The goal of this document is to provide a working structure that can help organize discussions with domain experts and make the reasoning process more explicit.

This structure may help elucidate medical-device failure scenarios, including the affected function, clinical or operational impact, teams involved, remediation tradeoffs, and return-to-service considerations. It can also inform AI-enabled tools that support vulnerability prioritization, remediation planning, or operational risk assessment in healthcare settings.

2. Background

Medical-device failures in hospitals are rarely simple technical events. A device may appear functional at the hardware level (i.e. able to achieve basic safety and essential performance of the medical device functions) but still fail within the clinical workflow if interoperability or network communication capability has been degraded, interfering with connects to other systems (such as PACS, EMR, modality worklist, nurse call or central monitoring, a drug library, vendor remote access, or another downstream system). Networked clinical systems should therefore be evaluated as part of a broader medical-device and hospital IT ecosystem, not as isolated assets (NIST SP 1800-24, *Securing Picture Archiving and Communication System (PACS): Cybersecurity for the Healthcare Sector*; IEC 80001-1, *Application of Risk Management for IT-Networks Incorporating Medical Devices*).

Remediation may not be straightforward. Applying a patch, isolating a device from the network, or removing a device from clinical service may reduce cybersecurity exposure, but it can also disrupt care delivery, reduce equipment availability, delay diagnosis or treatment, increase staff workload, or force manual workarounds (FDA, *Cybersecurity in Medical Devices: Quality System Considerations and Content of Premarket Submissions*; MITRE, *Medical Device Cybersecurity Regional Incident Preparedness and Response Playbook*).

For this reason, hospitals usually evaluate device issues through a combined technical, clinical, operational, and safety lens. The practical question is not only “Is this device vulnerable?” but also “What function is affected, who depends on it, what happens if it is taken offline, and what is required before it can safely return to service?” (Health Sector Coordinating Council, *Medical Device and Health IT Joint Security Plan*; Health Sector Coordinating Council, *Managing Legacy Technology Security*).

3. How Hospital Teams Reason Through Device Problems

3.1 Identify the affected asset

The first step is usually to identify what is affected (or is at risk for being affected based on newly disclosed vulnerabilities etc.). This includes device type, make/model, software or firmware version, clinical location, network connectivity, patient-connected status, responsible team, and backup availability.

This reflects the broader role of clinical engineering and health technology management, which includes device inventory, maintenance, safety, lifecycle management, and operational readiness (WHO, *Health Technology Management / Clinical Engineering*; Iadanza et al., *Evidence-Based Medical Equipment Management*).

3.2 Determine the current device state

A device is not simply “working” or “not working.” It may be:

- fully offline
- unsafe to use
- degraded but usable
- working locally but disconnected from the network
- unable to send or receive data
- usable only with a manual workaround
- unavailable because of patching, servicing, or validation

This distinction matters because some failures are obvious while others are silent. For example, a patient monitor display crash is immediately visible, but failed data transfer, failed archival, or incorrect routing may only be discovered later.

3.3 Identify the clinical or operational dependency

The next step is to determine who or what depends on the device. A device may support monitoring, therapy delivery, imaging, documentation, alarm routing, medication safety, procedure guidance, or clinical decision-making.

The same device can carry different levels of urgency depending on where and how it is used. A vulnerable monitor in an ICU, an infusion pump delivering high-risk medication, or a CT scanner used for emergency stroke imaging has a different priority than a similar device in storage or low-acuity use. Risk-based maintenance frameworks emphasize device criticality, utilization, failure consequence, downtime, repair burden, and patient waiting burden as part of prioritization (Taghipour, Banjevic, and Jardine, *Prioritization of Medical Equipment for Maintenance Decisions*; Jamshidi et al., *A Comprehensive Fuzzy Risk-Based Maintenance Framework for Prioritization of Medical Devices*).

3.4 Trace the failure pathway

A useful way to document a failure is:

trigger -> affected device function -> workflow dependency -> clinical or operational impact -> workaround -> remediation decision

Example:

software vulnerability -> device is isolated from the network -> downstream data transfer stops -> clinical documentation or review is delayed -> manual workaround is needed -> team decides whether isolation is acceptable or whether another mitigation is required.

This approach is consistent with healthcare failure-mode analysis, where teams map a process, identify failure modes, evaluate causes and effects, and decide whether action is needed (VA National Center for Patient Safety, *Healthcare Failure Mode and Effect Analysis Guidebook*; CMS, *Guidance for Performing Failure Mode and Effects Analysis*).

3.5 Choose the safest immediate action

Hospital teams often compare several options rather than automatically applying the most technically obvious fix.

Option	Benefit	Risk / Tradeoff
Patch now	Reduces cybersecurity exposure	Device or system may be unavailable during care
Delay patch	Preserves clinical availability	Vulnerability remains exposed
Isolate from network	Reduces exploitability	May break data flow, monitoring, reporting, or integration
Use backup device	Maintains clinical service	Backup may be unavailable, limited, or lower capability
Manual workaround	Keeps workflow moving	Higher error risk and documentation burden
Remove from service	Safest when device is unsafe	Reduces clinical capacity

The decision depends on clinical criticality, timing, backup capacity, vendor constraints, patch availability, downtime risk, patient-care impact, and post-remediation validation requirements. Legacy devices add further complexity because they may run older operating systems, depend on vendor approval, or be difficult to patch without affecting clinical operations (Health Sector Coordinating Council, *Managing Legacy Technology Security*; IHE Patient Care Device, *Cybersecurity Best Practice Guide*).

3.6 Validate before return to service

Before a device is returned to clinical use, the responsible team may need to confirm that it powers on, passes functional checks, meets safety or calibration requirements, reconnects to required systems, supports alarms or safety functions, and is documented in the service record or CMMS.

“Fixed” does not only mean the device turns on. It means the device is safe, functional, connected where needed, documented, and ready for the expected clinical workflow (Iadanza et al., *Evidence-Based Medical Equipment Management*; AAMI, *Certified Biomedical Equipment Technician Body of Knowledge*).

4. Who Is Involved?

Medical-device failure management is rarely owned by one group. Responsibility depends on where the problem appears, what function is affected, and whether the issue is clinical, device-level, network-level, cybersecurity-related, or workflow-related.

Clinical users often detect the problem first because they are contacted when clinicians see the failure during care or it is detected during routine maintenance. Biomedical or clinical engineering teams typically evaluate device function, device safety, maintenance status, and return-to-service readiness. IT, OT, cybersecurity, PACS, and integration teams become involved when the failure affects connectivity, data flow, software updates, image routing, EMR integration, network segmentation, or vulnerability response. Vendors may be required when the device is proprietary, when patches must be manufacturer-approved, or when post-update validation is required.

Task or issue	Commonly involved groups	Reason
Device problem noticed during care	Nurses, physicians, technologists, respiratory therapists, OR staff	Clinical users are often first to detect the problem
Initial patient-care impact assessment	Clinician, charge nurse, department leadership	They know whether care is immediately affected
Hardware/device malfunction	Biomedical or clinical engineering	They inspect, troubleshoot, repair, remove, or replace devices
Safety check / return to service	Biomedical or clinical engineering	They confirm safe and functional use before return
Network connectivity failure	IT network, OT, clinical engineering	Issue may be device-side, network-side, or integration-side
Cybersecurity vulnerability	Cybersecurity, IT/OT, clinical engineering, vendor	Requires technical risk and clinical-use assessment
Patch/remediation decision	IT/security, clinical engineering, vendor, department leadership	Patching may create downtime or workflow disruption
Imaging/data routing issue	PACS administrator, integration team, radiology operations, clinical engineering	Failure may involve device, routing, worklist, archive, or interface
EMR/HL7/worklist issue	Integration/interface team, IT, clinical operations	These are system-to-system communication problems
Medication device issue	Pharmacy, nursing, biomed, IT/vendor	Drug libraries, pump settings, and medication safety may be affected
Final decision to use workaround	Clinical leadership, clinicians, biomed/IT input	Patient-care risk must be owned operationally

This division of responsibility is consistent with medical-device network risk management frameworks, which emphasize shared roles across healthcare delivery organizations, IT networks, medical-device users, manufacturers, and risk-management stakeholders (IEC 80001-1, *Application of Risk Management for IT-Networks Incorporating Medical Devices*; IMDRF, *Principles and Practices for Medical Device Cybersecurity*; Health Sector Coordinating Council, *Medical Device and Health IT Joint Security Plan*).

5. Key failure-mode categories

5.1 Device unavailable or offline

A device may become unavailable because of hardware failure, software crash, network outage, patching, maintenance, cybersecurity incident, or removal from service. The clinical impact depends on device role, location, and availability of alternatives.

Example: a patient monitor vulnerability may require network isolation or removal from service. In an ICU or step-down unit, this can reduce monitoring capacity or require manual checks and replacement devices (FDA/CISA, *Contec CMS8000 and Epsimed Patient Monitor Vulnerabilities*; CISA, *Contec CMS8000 Firmware Backdoor Analysis*).

5.2 Device works locally but workflow fails

Some failures do not stop the device from performing its core local function but still break the clinical workflow. A device may collect data, acquire measurements, or perform local operations, but fail to transmit, archive, route, document, or synchronize that information downstream.

This type of failure can be missed if teams only ask whether the device “works.” The better question is whether the full clinical workflow still works.

Relevant sources: NIST SP 1800-24, *Securing PACS*; Eichelberg, Kleber, and Kämmerer, *Cybersecurity in PACS and Medical Imaging: An Overview*.

5.3 Data integrity or clinical information integrity failure

Some failures affect the trustworthiness of clinical information rather than availability. This includes corrupted data, altered images, incorrect patient association, manipulated parameters, incomplete records, or unreliable outputs.

These failures are important because a system may remain available while producing information that is incomplete, delayed, or wrong. Imaging cybersecurity literature describes risks involving DICOM manipulation, malicious HL7 messages, image tampering, altered scan protocols, disrupted reconstruction workflows, and denial-of-service (Eichelberg et al., *Cybersecurity Challenges for PACS and Medical Imaging*; Mahler et al., *Know Your Enemy: Characteristics of Cyber-Attacks on Medical Imaging Devices*).

5.4 Therapy delivery interruption or unsafe configuration

Devices that deliver therapy create direct patient-safety concerns when they fail or are compromised. Infusion pumps and insulin pumps are clear examples because vulnerabilities can affect dose delivery, device configuration, therapy interruption, or medication safety.

Example: wireless insulin pump vulnerabilities have been described where unauthorized communication could alter insulin delivery. This is a direct cyber-to-physical risk pathway (CISA, *Medtronic MiniMed Insulin Pump Vulnerability Advisory*; NHS Digital, *Medtronic MiniMed 600 Series Cyber Alert*).

5.5 Remote-access or vendor-support vulnerability

Many medical devices include vendor remote-support tools or embedded third-party software. These components may introduce vulnerabilities that the hospital cannot fully remediate without manufacturer involvement.

Example: remote-access components may allow file access, configuration changes, remote code execution, or denial-of-service. Remediation may depend on manufacturer patches, downtime planning,

and post-update validation (CISA, *PTC Axeda Access:7 Advisory*; Health Sector Coordinating Council, *Medical Device and Health IT Joint Security Plan*).

5.6 Patching or remediation causes disruption

Patching is intended to reduce risk, but it may also disrupt clinical operations if it removes a system from service, changes device behavior, breaks compatibility, or requires post-update validation. This is especially important for high-use devices, legacy systems, or systems that support multiple downstream workflows.

Healthcare patching studies show that software security patching can be associated with operational disruption and therefore requires planning, communication, and risk-aware scheduling (Jabin et al., *Operational Disruption in Healthcare Associated with Software Security Patching*).

6. Use cases / case examples

Use Case 1: Patient monitor vulnerability

A networked patient monitor has a vulnerability that could allow device crash, remote control, unexpected behavior, corrupted data, or patient data exposure. The issue is not only confidentiality. The clinical concern is that monitoring may become unavailable or unreliable.

The involved groups may include nursing staff, clinical engineering, cybersecurity, IT/network teams, the vendor, and unit leadership. If no patch is available, the hospital may need to isolate the device, remove it from service, increase manual monitoring, or substitute backup monitors. The tradeoff is between reducing cyber exposure and maintaining adequate monitoring capacity (FDA/CISA, *Contec CMS8000 and Epsimed Patient Monitor Vulnerabilities*; CISA, *Contec CMS8000 Firmware Backdoor Analysis*).

Use Case 2: Infusion pump configuration risk

An infusion pump vulnerability may allow unsafe configuration changes, therapy interruption, or unauthorized access to device settings. Because the device supports medication delivery, the clinical impact may include delayed therapy, incorrect dosing, or increased nursing and pharmacy burden. The involved groups may include nursing, pharmacy, biomedical engineering, IT/security, vendor support, and clinical leadership. Remediation may require inspection, software update, drug library verification, pump replacement, or temporary operational controls (CISA, *Medtronic MiniMed Insulin Pump Vulnerability Advisory*; Bracciale et al., *Cybersecurity Vulnerability Analysis of Medical Devices Purchased by National Health Services*).

Use Case 3: Imaging system or PACS disruption

An imaging system or PACS-related component may be affected by malware, network compromise, malicious DICOM/HL7 content, image manipulation, or denial-of-service. The clinical impact may include delayed interpretation, unavailable images, repeated imaging, or reduced trust in image integrity. The involved groups may include radiology technologists, radiologists, PACS administrators, imaging informatics, clinical engineering, IT/security, network teams, and vendors. Remediation may require isolating affected systems, validating image routing, checking integrity, restoring access, and confirming that clinical workflows are functioning before return to normal operations (NIST SP 1800-24, *Securing PACS*; Eichelberg et al., *Cybersecurity Challenges for PACS and Medical Imaging*; Mahler et al., *Know Your Enemy: Characteristics of Cyber-Attacks on Medical Imaging Devices*).

Use Case 4: Vendor remote-access vulnerability

A medical device or device-management system includes remote-support software that is later found to be vulnerable. The hospital may not be able to patch it independently because the software is embedded in vendor-controlled device infrastructure.

The involved groups may include IT/security, clinical engineering, vendor support, procurement or device management, and clinical operations if downtime is required. The remediation may involve vendor coordination, network segmentation, compensating controls, staged patching, and post-remediation validation (CISA, *PTC Axeda Access:7 Advisory*; Health Sector Coordinating Council, *Medical Device and Health IT Joint Security Plan*).

Use Case 5: Legacy device with known vulnerability

A clinically important device runs older software and has a known vulnerability, but patching is not immediately available or may affect device certification, compatibility, or clinical function.

The involved groups may include clinical engineering, IT/security, the vendor, department leadership, and possibly risk management. The hospital may need to use compensating controls, restrict network access, monitor traffic, schedule replacement, or accept temporary residual risk while preserving clinical service (Health Sector Coordinating Council, *Managing Legacy Technology Security*; IHE Patient Care Device, *Cybersecurity Best Practice Guide*).

7. Suggested Failure-Mode Template

Field	Description
Device / asset	Monitor, pump, imaging system, PACS node, router, server, remote-support software
Location	ICU, ED, OR, radiology, outpatient, lab, storage
Trigger	Device failure, patch event, CVE, network issue, configuration issue, vendor alert
Affected function	Monitoring, therapy delivery, imaging, reporting, documentation, routing, archival
Device state	Offline, degraded, locally usable, unsafe, disconnected, pending validation
Downstream dependency	EMR, PACS, worklist, DICOM, HL7, drug library, central monitoring, vendor system
First detector	Nurse, technologist, physician, biomedical engineer, IT alert, security alert, vendor notice
Responsible teams	Clinical staff, biomed/clinical engineering, IT/OT, cybersecurity, PACS/integration, vendor
Clinical impact	Delayed diagnosis, missed deterioration, therapy interruption, repeated procedure
Operational impact	Downtime, manual workaround, staff burden, reduced capacity
Remediation options	Patch, isolate, defer, replace, monitor, vendor escalation
Tradeoff	Risk reduction versus clinical availability
Return-to-service validation	Functional test, safety test, connectivity test, workflow test, documentation

8. Summary

The first objective is to understand existing hospital practice: how device problems are detected, who becomes involved, how the source of the problem is localized, how clinical impact is assessed, how downtime is managed, and how return to service is validated.

Useful failure-mode examples should explain what function is affected, which teams are involved, what workflow depends on the device, what clinical or operational impact follows, what workaround exists, and what tradeoff the hospital faces when deciding whether to patch, isolate, defer, replace, or return the device to service.

This framing can serve as a practical guide for AI-enabled tools that aim to support vulnerability prioritization or remediation planning in healthcare environments. These tools should not rely on technical severity alone. They should be guided to consider device function, clinical setting, downstream dependencies, patient-care impact, operational constraints, available workarounds, and return-to-service requirements. Final decisions should remain with the appropriate hospital teams and domain experts.

9. References and published evidence and case studies

Core failure-mode / risk-analysis methodology

1. MITRE / FDA / MDIC - Playbook for Threat Modeling Medical Devices
Use for structured threat modeling: asset, threat, vulnerability, attack path, system impact, patient-safety impact, and mitigation.
2. VA National Center for Patient Safety - Healthcare Failure Mode and Effect Analysis Guidebook
Use for healthcare-specific failure-mode analysis: process mapping, failure modes, causes, severity, probability, and control actions.
3. CMS - Guidance for Performing Failure Mode and Effects Analysis
Use for basic FMEA structure and proactive identification of failures and effects.

Medical-device cybersecurity and hospital remediation

4. FDA - Cybersecurity in Medical Devices: Quality System Considerations and Content of Premarket Submissions
Use for linking cybersecurity to device safety, effectiveness, system impact, and risk controls.
5. MITRE - Medical Device Cybersecurity Regional Incident Preparedness and Response Playbook
Use for hospital-level response, downtime planning, communication, continuity of care, and incident preparedness.
6. Health Sector Coordinating Council - Medical Device and Health IT Joint Security Plan
Use for lifecycle cybersecurity, vulnerability disclosure, patching, network controls, and manufacturer-healthcare organization coordination.
7. Health Sector Coordinating Council - Managing Legacy Technology Security
Use for legacy devices, difficult-to-patch systems, vendor constraints, and deployed hospital technology risk.
8. IEC 80001-1 - Application of Risk Management for IT-Networks Incorporating Medical Devices
Use for shared risk management across medical devices, hospital IT networks, clinical engineering, IT, security, and vendors.

9. IHE Patient Care Device - Cybersecurity Best Practice Guide
Use for practical device integration, patching constraints, manufacturer approval, CMMS/CMDB context, and networked patient-care device risk.
10. IMDRF - Principles and Practices for Medical Device Cybersecurity
Use for shared responsibility across manufacturers, healthcare delivery organizations, users, regulators, and cybersecurity stakeholders.

Clinical engineering / HTM reasoning and maintenance

11. WHO - Health Technology Management / Clinical Engineering
Use for the role of clinical engineering and HTM in inventory, installation, maintenance, and safe use.
12. Iadanza et al. - Evidence-Based Medical Equipment Management
Use for maintenance decision-making based on device history, evidence, risk, and operational context.
13. Taghipour, Banjevic, and Jardine - Prioritization of Medical Equipment for Maintenance Decisions
Use for prioritization based on failure modes, failure frequency, consequence, detectability, downtime, repair burden, and patient waiting burden.
14. Jamshidi et al. - A Comprehensive Fuzzy Risk-Based Maintenance Framework for Prioritization of Medical Devices
Use for risk-based prioritization using device criticality, utilization, age, hazards, repair time, and expert judgment.
15. AAMI - Certified Biomedical Equipment Technician Body of Knowledge
Use for technician-level competencies: troubleshooting, fault identification, safety, maintenance, and documentation.
16. TechNation - Biomed 101: Seven-Step Troubleshooting Guide for HTM Professionals
Use for practical troubleshooting sequence: prioritize, verify, localize, repair, verify repair, document, return to service.
17. 24x7 Magazine - Troubleshooting Medical Equipment
Use for practical biomedical technician troubleshooting and distinguishing device, user, environment, and system-level issues.

Imaging / PACS / data-flow examples

18. NIST SP 1800-24 - Securing Picture Archiving and Communication System (PACS): Cybersecurity for the Healthcare Sector
Use for PACS ecosystem security, imaging workflow, and coordination across biomedical, IT, security, and clinical teams.
19. Eichelberg, Kleber, and Kämmerer - Cybersecurity in PACS and Medical Imaging: An Overview
Use for PACS, DICOM, image integrity, malware, and imaging-network cybersecurity risks.
20. Eichelberg et al. - Cybersecurity Challenges for PACS and Medical Imaging
Use for specific PACS/imaging attack scenarios, including malicious DICOM/HL7, image manipulation, and PACS disruption.
21. Mahler et al. - Know Your Enemy: Characteristics of Cyber-Attacks on Medical Imaging Devices
Use for concrete imaging-device risks such as CT protocol tampering, radiation parameter manipulation, reconstruction disruption, and denial-of-service.

Real-world vulnerability case examples

22. FDA/CISA - Contec CMS8000 and Epsimed Patient Monitor Vulnerabilities
Use for patient-monitor risks, including device crash, remote control, corrupted data, loss of access, and lack of immediate patch.
23. CISA - Contec CMS8000 Firmware Backdoor Analysis
Use for device-level vulnerability analysis, data exfiltration, remote access, and mitigation constraints.
24. CISA - Medtronic MiniMed Insulin Pump Vulnerability Advisory
Use for wireless device communication vulnerabilities and direct therapy-delivery risk.
25. NHS Digital - Medtronic MiniMed 600 Series Cyber Alert
Use for therapy-device vulnerability resulting in too much, too little, slowed, or stopped insulin delivery.
26. CISA - PTC Axeda Access:7 Advisory
Use for remote-support component vulnerabilities, vendor dependency, and supply-chain remediation challenges.
27. Bracciale et al. - Cybersecurity Vulnerability Analysis of Medical Devices Purchased by National Health Services
Use for evidence that vulnerabilities are present across real medical-device procurement records and multiple device classes.
28. Jabin et al. - Operational Disruption in Healthcare Associated with Software Security Patching
Use for showing that software security patching itself can disrupt healthcare operations and requires planning.